

SentinelForge Architecture Overview

SentinelForge is an autonomous security analysis platform built for private environments.

It operates with zero external cloud dependencies, ensuring source code never leaks.

Key architectural pillars include deterministic AST parsing, tri-store RAG retrieval, and isolated subprocess execution for security analysis.

CONF_OVERVIEW_PAGE1: Privacy-first architecture guarantees zero external cloud telemetry.

Authentication Architecture and Token Lifecycle

The authentication subsystem provides cryptographic token generation and validation.

AuthService implements JSON Web Tokens (JWT) using HMAC-SHA256 signature verification.

Tokens contain subject IDs, authorization scopes, and issuance timestamps.

Clock skew tolerance is enforced to prevent replay attacks and expired credential exploitation.

CONF_AUTH_PAGE2: AuthService validates cryptographic JWT tokens and prevents clock skew.

Database Architecture and Unified Storage Responsibilities

SentinelForge coordinates a unified tri-store storage layer to deliver hybrid retrieval.

Relational metadata, canonical page records, and knowledge graph edges are persisted in SQLite.

Dense semantic embeddings are stored locally within an embedded ChromaDB collection.

In-memory BM25 indexes keyword frequency for exact symbol and syntax matching.

CONF_STORAGE_PAGE3: Tri-store storage layer coordinates SQLite, ChromaDB, and in-memory BM25

Defensive Sandbox Architecture and Execution Limits

The defensive sandbox enforces strict process isolation for executing external commands.

Execution limits cap CPU runtime at five seconds and memory consumption at two hundred megabytes.

Network restrictions drop all inbound and outbound socket connections to eliminate data exfiltration.

Filesystem isolation restricts write operations strictly to the workspace jail boundary.

CONF_SANDBOX_PAGE4: Defensive sandbox enforces process isolation, memory limits, and network ja

Testing Strategy and Verification Governance

The testing framework validates accuracy, security guardrails, and deterministic behavior.

Automated regression suites evaluate retrieval precision using Reciprocal Rank Fusion.

Security vulnerability checks test prompt injection sanitization against adversarial inputs.

Human-in-the-loop (HITL) approval gates require explicit authorization before applying code patches.

CONF_TESTING_PAGE5: Security regression tests enforce HITL human approval for code patches.